GRC REPORT

Name: Emmanuel Sunday Ayodimeji
Task Title: Governmenance, Risks & Compliances
Pseudo Organization: Tes Tech

Introduction

The Governance, Risk, and Compliance (GRC) sprint at TesTech, a pseudo-organization modeled after a modern automotive manufacturing company, was initiated to establish key cybersecurity policies aligned with ISO/IEC 27002:2022 standards and local regulatory requirements such as the Nigeria Data Protection Act (NDPA) 2023. As a security-first enterprise operating with high levels of automation and supply chain dependency, TesTech required a strong, structured policy framework to support its cybersecurity strategy.

The sprint was structured as a collaborative team activity where each member was assigned a key role and tasked with developing specific cybersecurity policies. In my role as Security Engineer, I was assigned to draft the Information Security Incident Management Policy. Additionally, I had the responsibility of presenting the final sprint deliverables to the coordinator on behalf of the entire team, which required a deep understanding of all components of the sprint and the ability to communicate them effectively.

Assigned Responsibilities and Deliverables

Policy Development: Information Security Incident Management

As part of the sprint, I developed a comprehensive Information Security Incident Management Policy tailored to TesTech's manufacturing context. This policy provides a structured process for:

- Identifying, reporting, and managing cybersecurity incidents
- Ensuring rapid containment and mitigation
- Documenting incidents for audit and learning
- Ensuring compliance with ISO/IEC 27002:2022 Clauses 5.24 to 5.28

Key sections of the policy include:

- Document control (versioning, roles, review dates)
- Incident classification and response lifecycle
- Roles and responsibilities of the incident response team
- Post-incident reviews and escalation paths
- Organizational requirements like log retention and use of SIEM/EDR tools

The policy also mapped each objective and requirement directly to relevant ISO controls and compliance frameworks.

Presentation of Sprint Output to the Coordinators

Another significant contribution I made was presenting the entire team's sprint deliverables to the course coordinator. This involved:

- Summarizing all 10 developed policies, including 3 custom ones
- Explaining our policy framework (control page, ISO domain mapping, compliance tracker)
- Highlighting team roles and contributions

This task showcased my leadership, communication, and coordination skills, in addition to my technical expertise.

Lessons Learned

The Importance of Policy Frameworks

This sprint highlighted how critical a policy framework is to the cybersecurity posture of an organization. A good framework ensures all policies:

- Are consistent in structure and content
- Align with international standards like ISO/IEC 27002
- Are easily monitored, updated, and enforced

Balancing Technical and Regulatory Needs

Developing the Incident Management Policy taught me to balance technical defense measures (like detection, containment, and SIEM tools) with regulatory requirements such as breach notification timelines and audit logging.

Real-World Policy Implementation Challenges

I realized that policy writing isn't just documentation, it requires:

- Clear role mapping (CISO, InfoSec Manager, Engineers, etc.)
- Regular review cycles
- Feedback mechanisms
- Automated tracking and audit readiness

Team Collaboration and Ownership

Working in a cross-functional GRC sprint taught me how to align with team members from different roles (IAM Specialist, Policy Analyst, etc.), and helped reinforce the need for mutual accountability and shared understanding of security goals.

Conclusion

The GRC sprint was a hands-on, practical experience that bridged the gap between theoretical cybersecurity frameworks and real-world enterprise implementation. As Security Engineer, I had the opportunity to take ownership of a critical policy area, incident management which is central to organizational resilience.

My additional role as the team's presenter pushed me to master not just my contribution but also to understand and communicate the entire team's work, which significantly improved my leadership and reporting skills.

Overall, the sprint gave me a clearer understanding of how cybersecurity policies are formulated, integrated, and maintained in a modern organization. It also highlighted the importance of cross-functional collaboration and communication when building secure and compliant environments.

I am confident that the skills and insights gained from this exercise will serve as a strong foundation in future cybersecurity governance roles.